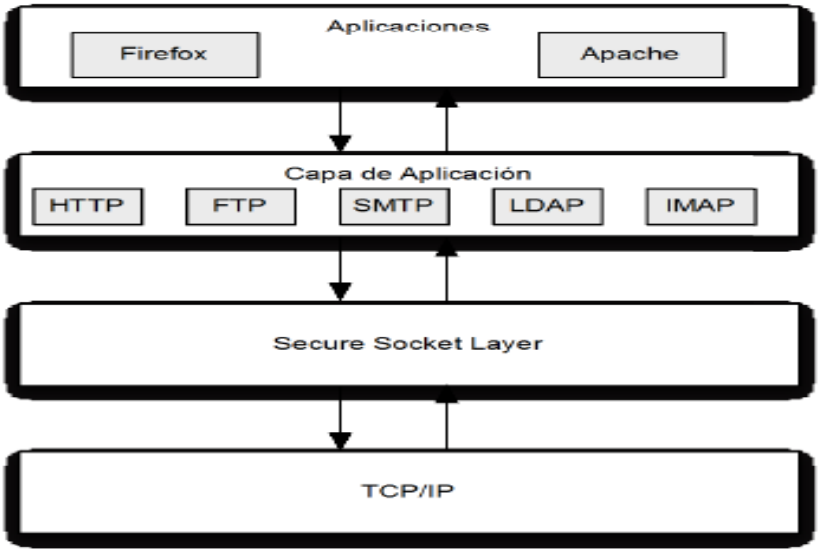
UD 2. ADMINISTRACIÓN DE SERVIDORES WEB

10. HTTPS

Sus siglas se corresponden con Hypertext Transfer Protocol Secure lo que ya indica que añade seguridad a HTTP. Realmente no es un protocolo sino que se basa en introducir una capa con el **protocolo SSL/TLS** entre la capa de transporte y la capa de aplicación en el conjunto de protocolos TCP/IP. Mediante el uso de SSL/TLS, HTTPS consigue que la comunicación en la web sea segura.



SSL/TLS

Secure Socket Layer (SSL) fue desarrollado por Netscape en los años 90. Han existido tres versiones de SSL pero actualmente se utiliza la 3.0. Ha derivado en otro protocolo Transport Layer Security (TLS) que también tiene tres versiones, la 1.0, la 1.1 y la 1.2.

Es un protocolo que se utiliza para asegurar **confidencialidad**, **autenticidad**, **integridad** y **no repudio** entre el cliente y el servidor.

Confidencialidad: La confidencialidad se entiende en el ámbito de la seguridad informática, como la protección de datos y de información intercambiada entre un emisor y uno o más destinatarios frente a terceros.

Integridad: Es la propiedad que busca mantener los datos libres de modificaciones no autorizadas.

Autenticación o autentificación: Propiedad que permite identificar el generador de la información.

No repudio: Propiedad que prueba que el autor envió la comunicación (no repudio en origen) y que el destinatario la recibió (no repudio en destino)

La seguridad de las transacciones a través de SSL se basa en el intercambio de claves entre un cliente y un servidor. Una transacción segura SSL de manera simplificada sigue el siguiente modelo:

- Primero, el cliente se conecta al servidor comercial protegido por SSL y pide la autenticación. El cliente también envía la lista de los criptosistemas que soporta, clasificada en orden descendente por la longitud de la clave.
- El servidor que recibe la solicitud envía un certificado al cliente que contiene la clave pública del servidor firmado por una entidad de certificación (CA), y también el nombre del criptosistema que está más alto en la lista de compatibilidades
- El cliente verifica la validez del certificado, luego crea una clave secreta al azar, cifra esta clave con la clave pública del servidor y envía el resultado al servidor (clave de sesión).
- El servidor es capaz de descifrar la clave de sesión con su clave privada. De esta manera, hay dos entidades que comparten una clave que sólo ellos conocen. Las transacciones restantes pueden realizarse utilizando la clave de sesión, garantizando la integridad y la confidencialidad de los datos que se intercambian.

La mayoría de servidores (entre ellos apache) ya implementan estos estándares, sólo necesitan de un certificado digital válido para poder establecer conexiones tipo HTTPS.

¿Pero qué es un certificado digital?

- Un certificado digital o certificado electrónico es un fichero informático generado por una entidad de servicios de certificación que asocia unos datos de identidad a una persona física, organismo o empresa confirmando de esta manera su identidad digital en Internet. El certificado digital es válido principalmente para autenticar a un usuario o sitio web en internet por lo que es necesaria la colaboración de un tercero que sea de confianza para cualquiera de las partes que participe en la comunicación. El nombre asociado a esta entidad de confianza es Autoridad Certificadora pudiendo ser un organismo público o empresa reconocida en Internet.

  El certificado digital tiene como función principal autenticar al poseedor pero puede servir también para cifrar las comunicaciones y firmar digitalmente

- Un Certificado Digital es un documento electrónico que enlaza una clave pública con una Firma Digital e información personal sobre la persona u organización que quiere usar la clave pública. Sirve para asegurar que esa clave pertenece a dicha persona u organización. La información personal que se adjunta suele ser el nombre, la dirección, el correo electrónico, etc. La Firma Digital suele ser la de una Entidad Certificadora reconocida para que los clientes puedan confiar en que la Clave Pública y la información personal corresponden a la misma persona/organización.

La firma digital de la entidad certificadora sobre el certificado avalará que el certificado es de fiar. Por tanto, podremos confiar en cualquier certificado digital firmado por una tercera parte en la que confiamos.

Cada certificado está identificado por un número de serie único y tiene un período de validez que está incluido en el certificado. El certificado y la clave pública se consideran información no sensible que puede distribuirse perfectamente a terceros.

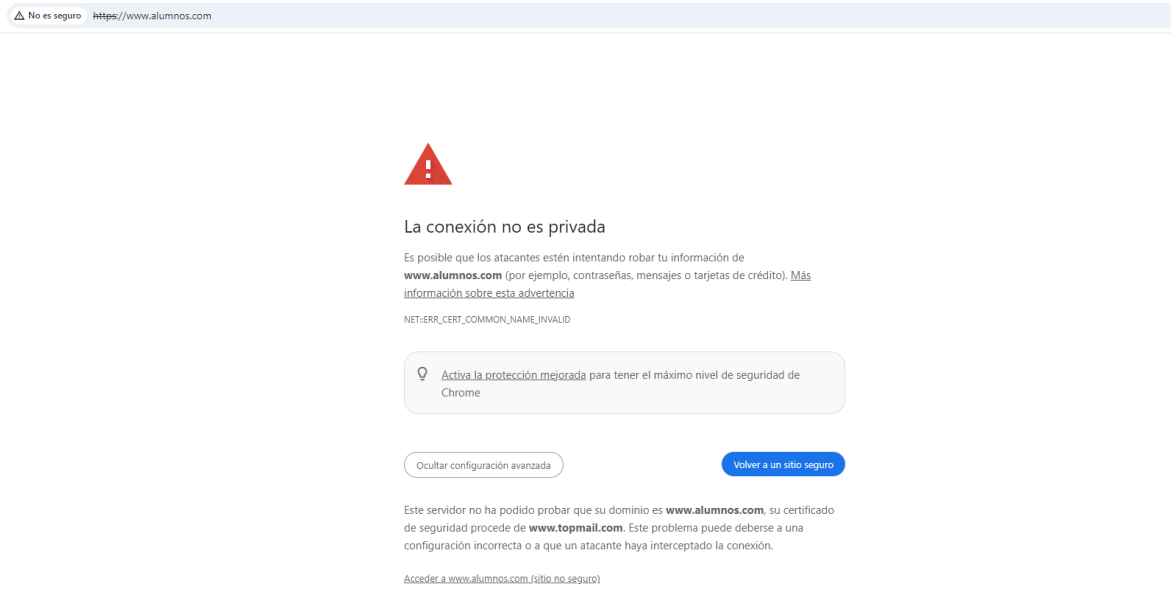
Instalando el Certificado Digital el servidor apache proporcionará automáticamente la información sobre la web al navegador de cualquier cliente si este está verificado y confirmado por una EC (Entidad Certificadora) o tercero confiable ésta confirmará que el

certificado es válido y garantizará la veracidad de los datos. Además toda comunicación se realizará a través del canal seguro que nos proporcion SSL garantizando la confidencialidad, autenticidad y privacidad de los datos.

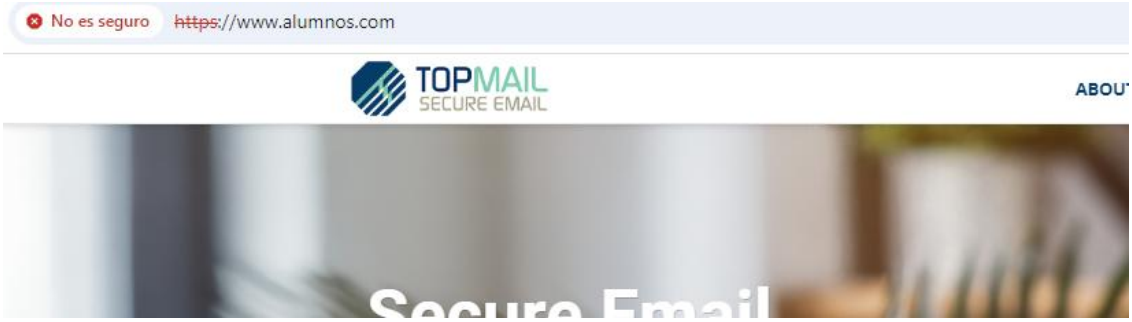
Existen tres condiciones para que el certificado sea válido y por lo tanto aceptado por la mayoría de navegadores. De no cumplirse estas tres condiciones el navegador alertará de la invalidez del certificado y en muchos casos recomendará al usuario abandonar la conexión.

- El nombre comun CN (Common Name) debe coincidir con la dirección URL del servidor. El navegador muestra una advertencia de seguridad si no coinciden.

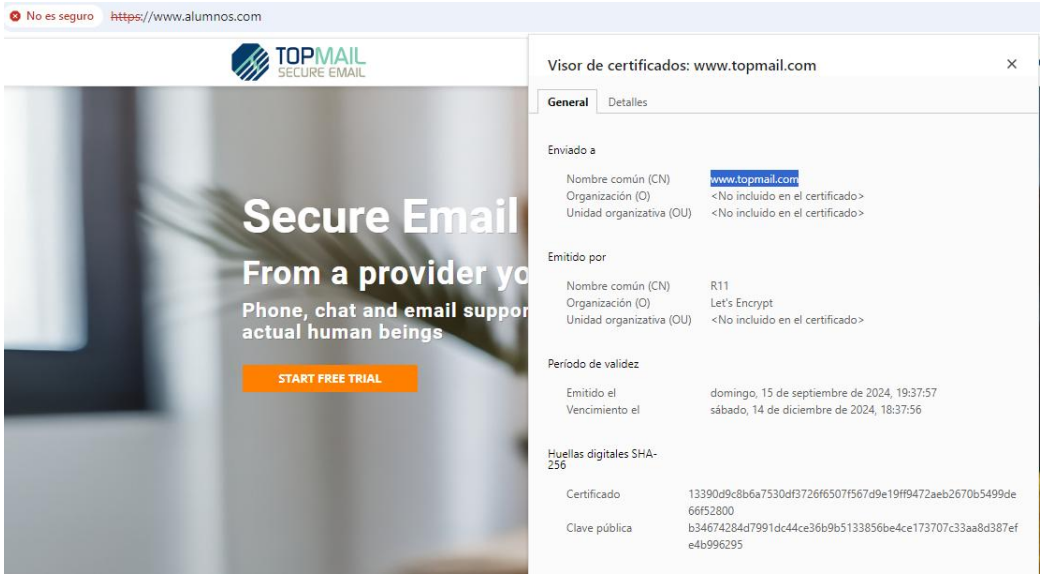
  Ejemplo: cuando vamos a conectarnos a www.alumnos.com aparece la advertencia (COMMON NAME INVALID) y tendremos que decidir si queremos seguir o preferimos no conectarnos con el destino.



Si continuamos:



En este caso el CN del certificado no coincide con el de la url por eso nos ha salido la advertencia.

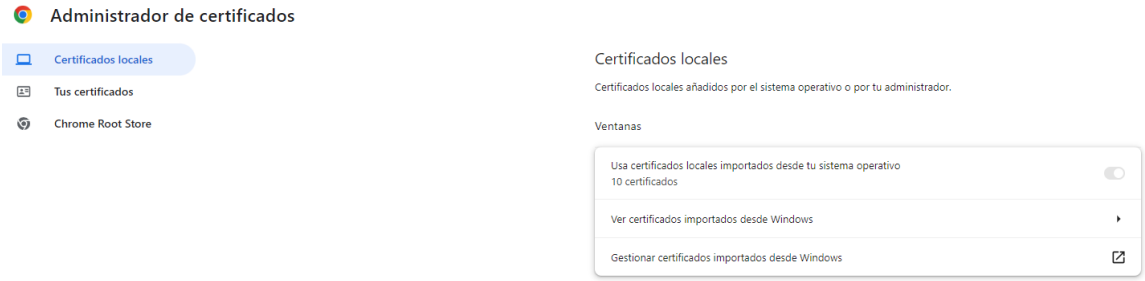


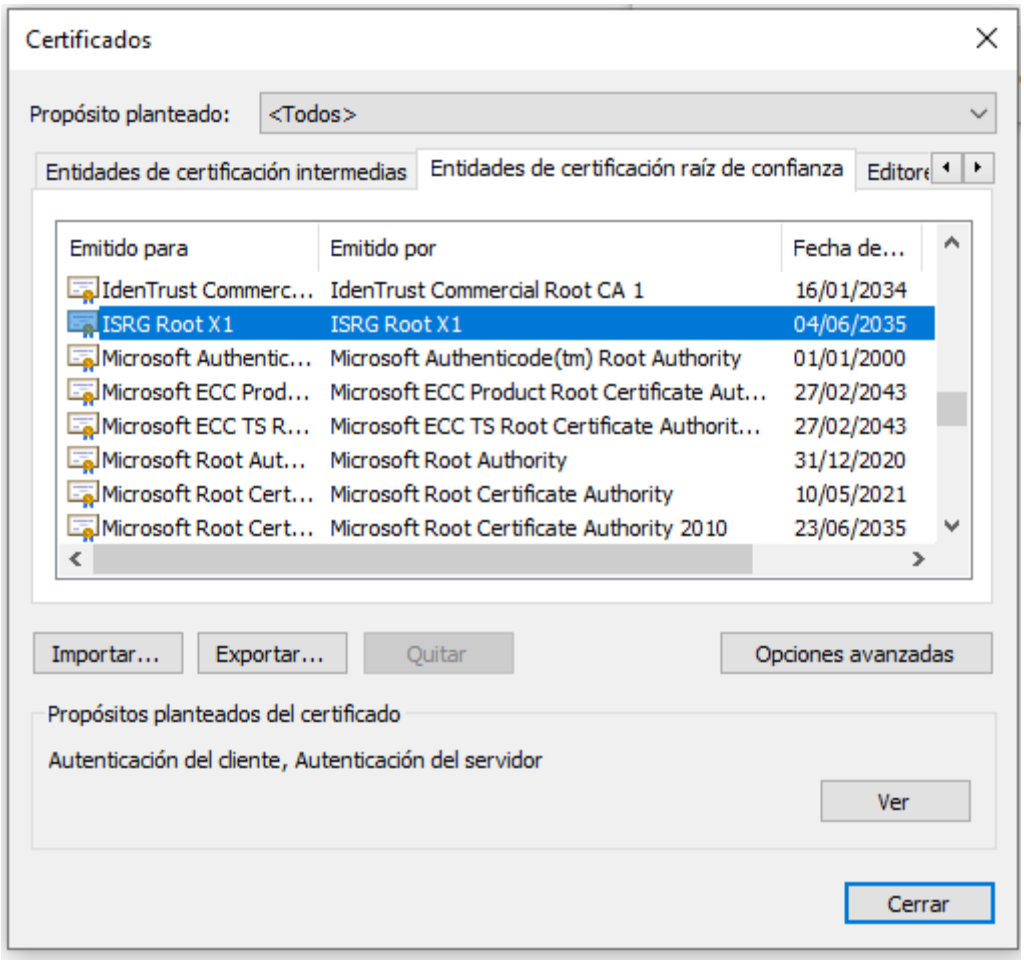
- El certificado debe estar firmado por una EC (Entidad Certificadora) en la que el browser o navegador del cliente haya depositado su confianza.

  Los navegadores web actuales basan el uso de HTTPS en el conocimiento de **Autoridades Certificadoras** que emiten **Certificados Digitales** para asegurar que el servidor al que nos conectamos es quien dice ser. El uso de HTTPS se basa en la confianza que nos proporcionan las entidades que emiten los certificados. Cuando usamos un navegador web determinado, la empresa que lo ha desarrollado ya ha introducido en él determinadas Autoridades Certificadoras que considera de confianza. Estas entidades se pueden consultar en el propio navegador y podemos modificarlas.

Actualmente los administradores de servidores web **adquieren certificados firmados por entidades certificadoras reconocidas**, así sus certificados ya están instalados en los navegadores de internet más populares.

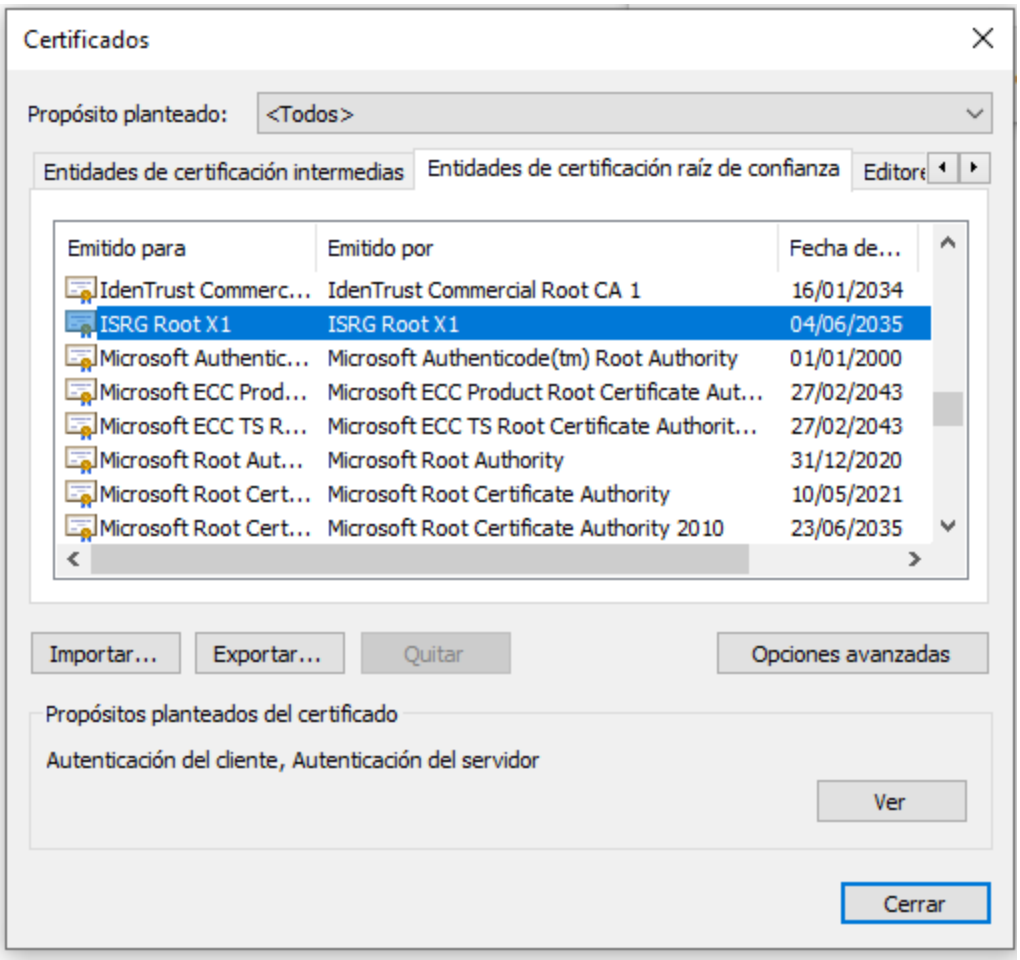
En la configuración del navegador Chrome, en gestionar certificados…





En el caso de www.aeducar.es, podemos comprobar que el certificado que usa el servidor está emitido por Let´s Encrypt.

Let's Encrypt es una autoridad de certificación (CA) gratuita, automatizada y abierta , que funciona para el beneficio del público. Es un servicio proporcionado por el Grupo de Investigación de Seguridad de Internet (ISRG). ISRG Root X1 es la autoridad de certificación raíz propia de Let's Encrypt . Observa que aparece en la lista de entidades de confianza.



Si un servidor usa un certificado no emitidos por estas autoridades, el navegador sacará la advertencia y depende del usuario el aceptarlos o no.

• Las fechas de validez del certificado deben corresponderse con las actuales

HTTPS es un poco menos eficiente que HTTP por lo que si se utiliza en sitios donde la transferencia de información es muy grande puede notarse en el rendimiento. Por supuesto en el caso de que la información trasferida sea sensible, las ventajas compensan con creces a los inconvenientes.

El protocolo HTTPS usa el puerto 443 por defecto. Al igual que sucedía con HTTP y el puerto 80, en caso de que se utilice este puerto no es necesario que el cliente lo indique en la barra de direcciones del navegador.

11. Configuración de http en Apache

CONFIGURACIÓN DE HOST VIRTUAL SEGURO POR DEFECTO EN APACHE

Apache cuenta con un host virtual seguro por defecto, el archivo de configuración es **default-ssl.conf.** Pasos para hacerlo funcionar:

1) habilitar el módulo ssl, reiniciar apache y comprobar que apache ya escucha por el puerto 443.

```
a2enmod ssl
netstat -ptan
```

Ojo que en ports.conf ya está habilitado el puerto si el módulo ssl está activo

```
<IfModule ssl_module>
     Listen 443
</IfModule>
```

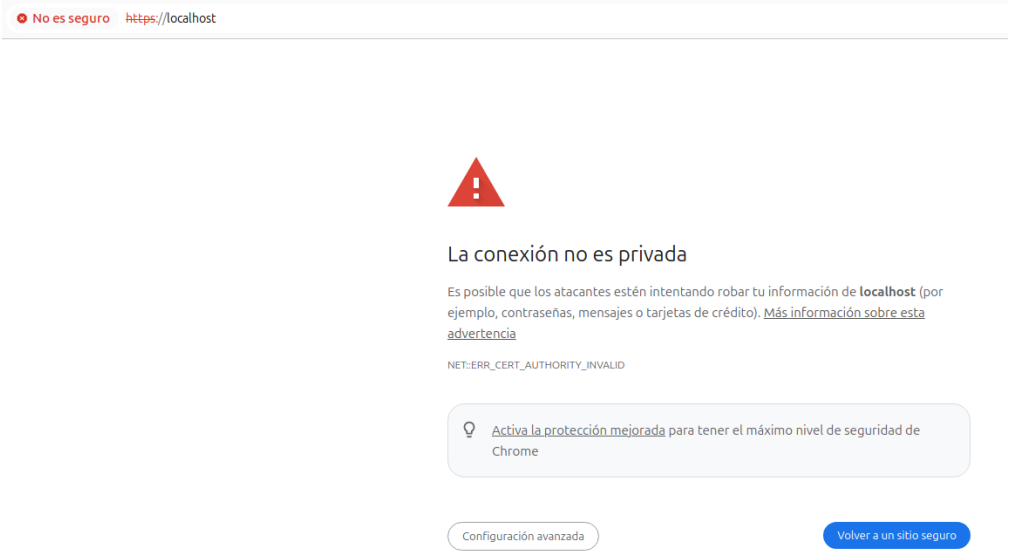
2) Habilitar el sitio **default-ssl.conf**. Fíjate en las directivas que indican el certificado y la clave por defecto…

```
SSLEngine on
SSLCertificateFile    /etc/ssl/certs/ssl-cert-snakeoil.pem
SSLCertificateKeyFile /etc/ssl/private/ssl-cert-snakeoil.key
```

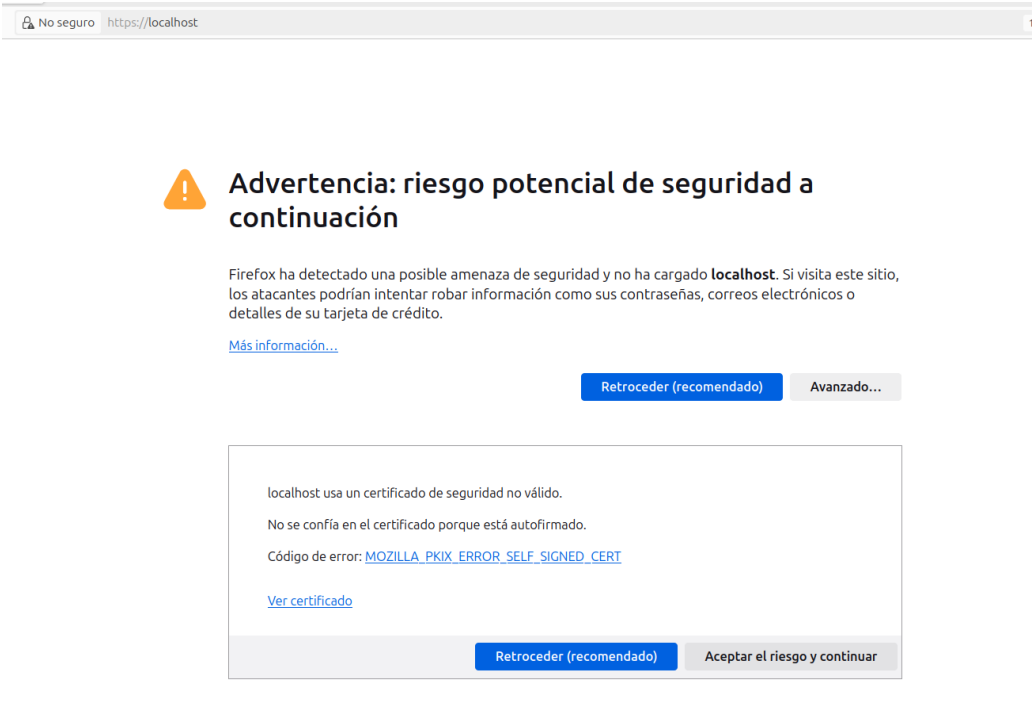
Dichos certificados “de aceite de serpiente” (Wikipedia: Snake oil (cryptography)) los genera el script de postinstalación del paquete ssl-cert de Ubuntu asociados al hostname del sistema.

Ya tenemos apache preparado para servir páginas de forma segura con el certificado que ofrece apache por defecto. Ahora ya podríamos conectarnos por HTTPS: https://nombreserver. Sin embargo, al estar usando el certificado “de aceite de serpiente”, lo que nos encontraremos será con que el navegador nos da una o dos advertencias sobre el dominio. Una segura porque el certificado no está firmado por una autoridad de confianza y tal vez otra porque el dominio, hostname o IP que estamos usando para acceder al sitio no coincida con el que indica el certificado.

En Chrome:



En Firefox:



Por otro lado, es una mala opción dejar abierta la posibilidad de acceder al mismo sitio mediante una conexión segura y una insegura. Por ello si habilitamos un sitio con HTTPS no deberíamos tener activo el equivalente con HTTP como sucede con los dos por defecto. Lo correcto sería deshabilitar el default.

Acabamos de ver que para poder usar https es necesario tener un certificado. Podemos adquirir uno de una CA o crear uno nosotros autofirmado.

OBTENER UN CERTIFICADO DIGITAL

Como ya se ha dicho para poder utilizar HTTPS en nuestro servidor es necesario disponer de un Certificado Digital. Podemos obtener un Certificado Digital de una Autoridad Certificadora (certificate authority, CA) (también es posible crear nuestra propia Autoridad Certificadora y generar nuestros propios Certificados Digitales aunque no lo realizaremos)

Hay varias empresas que venden certificados digitales firmados por autoridades certificadoras de confianza.

DigiCert: **Comodo (ahora Sectigo)**: **GlobalSignEntrust**: **GoDaddy**: **Thawte**: **RapidSSL**: **Let's Encrypt**

Los certificados digitales que venden las empresas para servidores pueden variar en varios aspectos. Por ejemplo, la duración del Certificado, el tipo (Certificados Únicos: Protegen un solo dominio (ej. www.ejemplo.com), Certificados Wildcard: Protegen un dominio y todos sus subdominios (ej. *.ejemplo.com), Certificados Multi-Dominio (SAN): Permiten proteger múltiples dominios con un solo certificado) el precio, la reputación…

PROCEDIMIENTO PARA CREAR CERTIFICADOS AUTOFIRMADOS USANDO OPENSSL

Vamos a crear un **certificado autofirmado** que conviene cuando no podemos desembolsar el costo de un certificado comercial, los usuarios son pocos y confían en nosotros. La desventaja es que la primera vez que ingresen al sitio, su navegador de internet pondrá una **advertencia de seguridad**; a la cual debemos de indicar que el sitio **sí es de confianza** y guardarla para que no nos pregunte en el futuro.

http://httpd.apache.org/docs/2.4/ssl/ssl_faq.html#selfcert

Primero, como un usuario común vamos a abrir una terminal en GNU/Linux y crear un directorio donde vamos a trabajar con los certificados.

```
mkdir apache-self-signed-cert
cd apache-self-signed-cert
```

Ejecuta el siguiente comando **openssl**

```
openssl req -x509 -nodes -days 1460 -newkey rsa:2048 -keyout sapache.key
-out sapache.crt
```

Este programa te preguntará datos importantes que ayudarán a identificar el certificado. En particular en *common name* use el nombre de domino completo del servidor.

```
Country Name (2 letter code) [AU]: **
State or Province Name (full name) [Some-State]: ******
Locality Name (eg, city) []: ******
Organization Name (eg, company) [Internet Widgits Pty Ltd]: ******
Organizational Unit Name (eg, section) []: ******
Common Name (e.g. server FQDN or YOUR name) []: sapache.com
Email Address []: webmaster@servidor.com
```

Copia los archivos creados al directorio donde **Apache** espere encontrarlos.

```
sudo cp * /etc/ssl/apache2/
```

Cambia los permisos de estos archivos como lo indican estos comandos:

```
sudo chmod 444 /etc/ssl/apache2/sapache.crt
sudo chmod 400 /etc/ssl/apache2/sapache.key
```

Ahora nos queda configurar el sitio o sistema web en **Apache** para que haga uso del cifrado **SSL** creando un nuevo archivo **conf**. Vamos a verlo

CONFIGURACIÓN DEL SERVIDOR SEGURO

1. Configuramos el servidor seguro con los parámetros. Lo llamaremos sapache.conf (habrá que configurarlo como un host virtual por nombre)
    a. Creamos el directorio del host virtual: sapachedir en el directorio /var/www

    ```
    mkdir /var/www/sapachedir
    ```

    añadiendo el archivo para visualizar sapache.html

    b. Hacemos copia del fichero de configuración default-ssl.conf, en el directorio sites-available llamándolo sapache.conf

    ```
    cp /etc/apache2/sites-available/default-ssl.conf sapache.conf
    ```

    y modificar DocumentRoot (`/var/www/sapachedir`), ServerName (sapache.com)

    c. Activamos el nuevo host

    ```
    a2ensite sapache.conf
    ```

    d. Modificar dentro de VirtuaHost el fichero sapache.conf con:

    ```
    SSLEngine on
    SSLCertificateFile    /etc/ssl/apache2/sapache.crt
    ```

```
SSLCertificateKeyFile /etc/ssl/apache2/sapache.key
```

2. Reiniciamos apache y probamos desde navegador y vemos la información que nos da del certificado autofirmado. Añadimos excepción de seguridad y la próxima vez ya entra sin preguntar. Si hubiéramos adquirido los certificados a través de una CA de confianza dejaría de aparecer el aviso cuando un cliente se conecta (para un sitio profesional es más que recomendable).